


# UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

## FACULTAD DE INGENIERÍA EN SISTEMAS DE INFORMACIÓN

### PROGRAMA DE POSGRADOS

**Proyecto**
**Entregable 1**

## Autor(es):

**De León Hernández Henry Ottoniel – hdeleonh@miumg.edu.gt**
**Sinay Alvarez Mynor Styven - msinaya2@miumg.edu.gt**
**Tejeda Hernández Luis Alfredo - ltejedah@miumg.edu.gt**
**Alvarado Barrientos Edgar Omar - ealvaradob2@miumg.edu.gt**
**González Álvarez Edu Emilio - egonzaleza15@miumg.edu.gt**

## Profesor

**Ing. Cesar Giovanni Rodríguez Minas**

**Seguridad en Aplicaciones – Cuarto Trimestre - 2026**

**Guatemala, Octubre del 2026**

## Resumen Ejecutivo

El proyecto tiene como propósito desarrollar una tienda en línea propia y evaluar su seguridad durante todo el ciclo de vida del software. El grupo construirá el frontend, la API, la base de datos y los procesos de administración. La solución se desplegará en una infraestructura cloud cuya configuración también formará parte de la evaluación. Desde la planificación se establecerán criterios para proteger las cuentas de clientes, los pedidos, la información personal y los servicios que permiten operar la tienda.

La propuesta comprende el diseño de una arquitectura segura, la programación de las funciones comerciales, la automatización de análisis de seguridad y la realización de pruebas sobre la aplicación y su infraestructura. Para orientar estas actividades se utilizarán OWASP ASVS 5.0.0, ISO/IEC 27001:2022, ISO/IEC 27005:2022 y el marco de desarrollo seguro de NIST. Los estándares ISO/IEC se publican conjuntamente por la International Organization for Standardization (ISO) y la International Electrotechnical Commission (IEC). La integración de prácticas seguras en el desarrollo está respaldada por el marco SSDF de NIST (ISO & IEC, 2022a, 2022b; OWASP Foundation, 2025a; Souppaya et al., 2022).

Como parte de la planificación se identificaron quince activos de referencia y catorce escenarios de amenaza para el modelo STRIDE. También se prepararon una valoración DREAD, una matriz de riesgos y veintinueve requisitos ASVS que servirán para orientar la implementación y la verificación posterior. Estas valoraciones corresponden al diseño propuesto y todavía deberán contrastarse con el código y el entorno de despliegue. Los pagos se contemplan mediante un servicio externo en ambiente de pruebas, sin almacenar números completos de tarjeta ni códigos de seguridad.

# Índice


Selección y Planificación ..... 1

Contexto del E-Commerce ..... 1

Objetivos ..... 2

Objetivo General ..... 2

Objetivos Específicos ..... 2

Alcance ..... 3

Normativas y Estándares ..... 4

Matriz inicial de requisitos de seguridad (ASVS 5.0.0) ..... 5

Definición del Scope Técnico ..... 9

Activos y Riesgos ..... 11

Inventario de Activos (ISO 27001) ..... 11

Clasificación CIA y Criticidad ..... 13

Modelado de Amenazas (STRIDE) ..... 14

Diagrama de contexto, nivel 0 ..... 14

Diagrama de arquitectura y flujo de datos, nivel 1 ..... 15

Diagrama de procesos internos, nivel 2 ..... 16

Clasificación de Riesgos (DREAD) ..... 20

Matriz de Riesgos Inicial ..... 21

Matriz de calor (probabilidad × impacto) ..... 23

Análisis obligatorio de siete capas de defensa ..... 23

Tratamiento preliminar y responsables ..... 24

Evaluación de Seguridad ..... 26

Pentesting Caja Negra ..... 26

Pentesting Caja Gris / Blanca ..... 26

Evaluación OWASP Web Top 10 ..... 26
Evaluación de componentes y librerías ..... 26
SAST del frontend y backend ..... 26
SCA de dependencias de la aplicación ..... 26
Evaluación de Contenedores y Kubernetes ..... 26
Mitigación y Ciberseguridad ..... 26
Rediseño Arquitectónico Cloud Seguro ..... 26
Controles de Seguridad Propuestos ..... 26
Hardening de la aplicación web ..... 26
Hardening del frontend y backend ..... 26
Hardening de Contenedores ..... 26
Hardening de Infraestructura Cloud ..... 26
Implementación de Controles DevSecOps ..... 26
Operaciones y Monitoreo ..... 26
WAF ..... 26
RASP / Protección en Tiempo de Ejecución ..... 26
SIEM / Correlación de Eventos ..... 26
Alertas y Dashboards ..... 26
Gestión Continua de Vulnerabilidades ..... 26
Tratamiento del Riesgo ..... 27
Conclusiones ..... 28
Recomendaciones Técnicas ..... 29
Roadmap de Seguridad Continua ..... 30
Lecciones Aprendidas ..... 31
Anexos ..... 32

Referencias ..... 33

## Índice de Tablas

Tabla 1. Normas, metodologías y función dentro del proyecto ..... 4

Tabla 2. Requisitos de seguridad seleccionados del ASVS 5.0.0 ..... 5

Tabla 3. Alcance técnico de referencia ..... 9

Tabla 4. Inventario de activos, responsables y acceso .....11

Tabla 5. Valoración CIA y justificación de criticidad..... 13

Tabla 6. Identificación de amenazas STRIDE..... 18

Tabla 7. Puntuación preliminar DREAD por escenario..... 21

Tabla 8. Criterios de probabilidad e impacto ..... 22

Tabla 9. Registro de riesgos inherentes estimados ..... 22

Tabla 10 Matriz de calor inicial ..... 23

Tabla 11. Riesgos y controles iniciales en siete capas..... 23

Tabla 12. Plan inicial de tratamiento por amenaza ..... 24

## Índice de Figuras

Figura 1. Flujo de datos conceptual y fronteras de confianza ..... 10

Figura 2. Diagrama de contexto de nivel 0 de la tienda en línea ..... 15

Figura 3. Arquitectura y fronteras de confianza ..... 16

Figura 4. Procesos de autenticación y compra ..... 17

# Selección y Planificación

## Contexto del E-Commerce

El proyecto consiste en desarrollar desde cero una aplicación web de comercio electrónico y ponerla en funcionamiento en la nube. La tienda permitirá explorar productos, crear cuentas, administrar un carrito y registrar pedidos. También tendrá un área administrativa para gestionar el catálogo, las existencias y el seguimiento de las ventas. El grupo será responsable del código de la aplicación, del modelo de datos y de la configuración técnica necesaria para su operación.

El desarrollo propio hace posible revisar las decisiones de seguridad junto con cada función que se programe. Se definirán mecanismos de autenticación, gestión de sesiones, autorización, validación de entradas y control de las operaciones de compra. El proceso incluirá revisiones del código y pruebas que permitan comprobar si los controles cumplen su propósito. El Secure Software Development Framework de NIST recomienda incorporar estas actividades al ciclo de vida del software (Souppaya et al., 2022).

La arquitectura de referencia propone React para el frontend, Node.js con Express para la API y PostgreSQL como base de datos. Docker se utilizaría para empaquetar los componentes de la aplicación y facilitar su despliegue. Se prevén servicios cloud para administrar secretos, copias de seguridad, conectividad y registros de operación. El proveedor y los servicios concretos se seleccionarán durante el diseño arquitectónico, considerando el costo, la disponibilidad de herramientas y los controles exigidos en el proyecto.

## Objetivos

### *Objetivo General*

Diseñar, desarrollar, desplegar y evaluar una aplicación web de comercio electrónico en la nube, incorporando controles de seguridad desde la definición de requisitos hasta su operación, mediante prácticas de desarrollo seguro, modelado de amenazas, verificación técnica y gestión continua de riesgos.

### *Objetivos Específicos*

1. Analizar los procesos de compra y administración de la tienda para definir sus funciones, activos de información, requisitos de seguridad y amenazas, utilizando STRIDE, DREAD y OWASP ASVS 5.0.0.
2. Diseñar una arquitectura cloud que separe los componentes públicos de los servicios internos y contemple autenticación, autorización, cifrado, gestión de secretos y control de acceso a los datos.
3. Desarrollar el frontend, la API y la base de datos de la tienda, aplicando validaciones en el servidor y controles para proteger las cuentas, los pedidos, los pagos y la integridad del inventario.
4. Integrar prácticas DevSecOps al proceso de desarrollo mediante control de versiones, revisión de código, análisis estático, revisión de dependencias y comprobaciones de seguridad en la entrega de software.
5. Realizar pruebas de seguridad de caja negra, gris y blanca, además de evaluaciones de la superficie de ataque, para identificar fallas y comprobar la eficacia de las medidas implementadas.
6. Configurar controles de protección y observabilidad que permitan gestionar vulnerabilidades, registrar eventos relevantes, detectar incidentes y dar seguimiento al funcionamiento de la aplicación.
7. Valorar los riesgos antes y después de aplicar controles, documentar los resultados de las pruebas y formular un plan de mejora continua con base en la evidencia reunida.

## Alcance

El proyecto comprende la construcción de una tienda en línea para usuarios visitantes, clientes registrados y personal administrativo. Se desarrollarán el catálogo de productos, las cuentas de usuario, el carrito, la gestión de pedidos, el inventario y las funciones de administración. La aplicación tendrá una API propia y una base de datos para guardar la información necesaria en cada operación. El diseño incluirá mecanismos de auditoría que permitan relacionar las acciones relevantes con sus responsables.

El alcance técnico incluye el diseño de la infraestructura cloud y la configuración segura de los componentes de la aplicación. Durante el desarrollo se incorporarán controles de autenticación, autorización por roles y por recurso, protección de sesiones, validación de datos y manejo seguro de errores. También se implementarán revisiones de código, análisis SAST y SCA, comprobaciones de contenedores, pruebas dinámicas, protección perimetral y mecanismos de registro y monitoreo. La evaluación se realizará en ambientes autorizados y comprenderá pruebas de caja negra, caja gris y caja blanca.

Los actores previstos son visitantes, clientes, administradores de la tienda, personal encargado de pedidos e inventario y miembros del equipo de desarrollo y operaciones. Para el proceso de pago se utilizará una simulación o la integración de un proveedor externo en su ambiente de pruebas. El sistema no realizará procesamiento bancario propio ni almacenará datos completos de tarjetas o códigos CVV. Aun cuando el pago se externalice, será necesario revisar las responsabilidades que correspondan al comercio y la seguridad de la integración (PCI Security Standards Council, s. f.). La ejecución del proyecto se organizará en etapas de planificación, arquitectura, desarrollo seguro, evaluación, despliegue y operaciones, conforme al enunciado del curso.

## Normativas y Estándares

ISO/IEC 27001:2022 establece requisitos para la gestión de la seguridad de la información y proporciona criterios para organizar responsabilidades y controles. ISO/IEC 27005:2022 ofrece orientación para identificar, analizar, evaluar y tratar riesgos. Estas referencias servirán para estructurar las decisiones de protección de la tienda y revisar los riesgos conforme avance el proyecto. Su utilización no implica que la aplicación o el equipo cuenten con una certificación (ISO & IEC, 2022a, 2022b).

OWASP ASVS 5.0.0 se utilizará para expresar requisitos de seguridad que puedan comprobarse en el código y en el comportamiento de la aplicación. Se propone trabajar hacia el nivel 2 en los requisitos que resulten aplicables, incluyendo los requisitos de nivel 1 correspondientes. Esta meta requiere implementar los controles y obtener evidencia de las verificaciones. Para facilitar la trazabilidad se conserva el identificador completo de cada requisito, como v5.0.0-8.2.2 (OWASP Foundation, 2025a).

OWASP Top 10:2025 aportará una referencia para revisar las principales familias de riesgos de aplicaciones web. STRIDE se empleará durante el diseño para identificar posibles amenazas y DREAD permitirá organizar una priorización inicial. Las prácticas recomendadas por NIST SP 800-218 orientarán la integración de la seguridad en el trabajo del equipo. Estas fuentes se complementan y se utilizarán según la actividad que corresponda a cada fase (OWASP Foundation, 2025b; Microsoft, 2022; Souppaya et al., 2022).

**Tabla 1. Normas, metodologías y función dentro del proyecto**

| Referencia | Versión | Aplicación en el proyecto |
|---|---|---|
| ISO/IEC 27001 | 2022 | Criterios de gestión, activos, responsabilidades y controles organizativos. |
| ISO/IEC 27005 | 2022 | Identificación, análisis y tratamiento preliminar de riesgos. |
| OWASP ASVS | 5.0.0 (2025) | Requisitos verificables para aplicación, sesiones, autorización y datos. |

**Continuación tabla 1**

| Referencia | Versión | Aplicación en el proyecto |
|---|---|---|
| OWASP Top 10 | 2025 | Contextualización de riesgos típicos de aplicaciones web. |
| STRIDE | Modelo de amenazas | Identificación de seis categorías de amenaza por flujo/componente. |
| DREAD | Modelo de puntuación | Priorización relativa mediante cinco factores de 1 a 10. |
| NIST SP 800-218 | SSDF v1.1 (2022) | Prácticas de seguridad integradas al desarrollo desde cero. |
| PCI DSS | Referencial, según alcance | Responsabilidades sobre pasarela de pago externalizada. |

*Nota.* El uso de estos estándares en la propuesta no equivale a una auditoría, certificación ni conformidad demostrada. Fuente: Elaboración Propia

### *Matriz inicial de requisitos de seguridad (ASVS 5.0.0)*

La matriz siguiente reúne controles que el proyecto deberá tener presentes durante el desarrollo y la evaluación de la tienda. Cada requisito incluye su identificador en OWASP ASVS 5.0.0, la evidencia prevista y las amenazas del apartado 2.3 con las que se relaciona. Las descripciones se han adaptado al contexto de la aplicación. Los controles se verificarán cuando existan los componentes correspondientes y haya un ambiente disponible para ejecutar las pruebas (OWASP Foundation, 2025a).

**Tabla 2. Requisitos de seguridad seleccionados del ASVS 5.0.0**

| Código | Nivel | Requisito adaptado al e-commerce | Evidencia prevista | Amenaza |
|---|---|---|---|---|
| v5.0.0-1.2.1 | L1 | Codificar salidas según contexto HTML, atributos y cabeceras para prevenir alteraciones/XSS. | Pruebas unitarias y manuales con entradas no confiables. | T07 |
| v5.0.0-1.2.4 | L1 | Usar parámetros u ORM seguro en todas las consultas de PostgreSQL. | Revisión del repositorio y pruebas controladas de inyección. | T08 |

**Continuación tabla 2**

| Código | Nivel | Requisito adaptado al e-commerce | Evidencia prevista | Amenaza |
|---|---|---|---|---|
| v5.0.0-2.2.1 | L1 | Validar datos, rangos y reglas comerciales de cantidades y descuentos. | Pruebas de valores inválidos y reglas de negocio. | T02, T14 |
| v5.0.0-2.2.2 | L1 | Aplicar la validación de entradas en una capa confiable del backend. | Tests de API sin frontend y revisión de servicios. | T02 |
| v5.0.0-2.3.1 | L1 | Impedir saltar pasos del proceso de compra o alterarlos de orden. | Pruebas de secuencia de checkout y estados de pedido. | T02, T09 |
| v5.0.0-2.3.3 | L2 | Realizar operaciones de pedido/inventario con transacciones atómicas. | Tests de rollback ante errores de compra. | T02, T14 |
| v5.0.0-2.3.4 | L2 | Establecer control de concurrencia sobre recursos con stock limitado. | Pruebas paralelas de compra sobre última unidad. | T14 |
| v5.0.0-2.4.1 | L2 | Aplicar antiautomatización a endpoints intensivos y sensibles. | Pruebas de límites por usuario/ruta y métricas. | T01, T05 |
| v5.0.0-3.3.4 | L2 | Proteger cookies de sesión con HttpOnly si no son accesibles a scripts. | Inspección de Set-Cookie y pruebas de sesión. | T01, T13 |
| v5.0.0-3.5.1 | L1 | Proteger operaciones sensibles entre orígenes con medidas antifalsificación. | Prueba CSRF sobre cambios con sesión activa. | T13 |
| v5.0.0-6.3.1 | L1 | Mitigar fuerza bruta y credential stuffing según documentación. | Pruebas de limitación de intentos y registro de eventos. | T01 |

**Continuación tabla 2**

| Código | Nivel | Requisito adaptado al e-commerce | Evidencia prevista | Amenaza |
|---|---|---|---|---|
| v5.0.0-6.3.3 | L2 | Adoptar autenticación multifactor o combinación de factores permitida. | Flujo de MFA administrativo y pruebas de recuperación. | T01, T06 |
| v5.0.0-7.1.1 | L2 | Documentar expiración por inactividad y máxima duración de sesión. | Política de sesión y pruebas de expiración. | T01 |
| v5.0.0-7.2.4 | L1 | Renovar e invalidar token previo en autenticación/reautenticación. | Pruebas de fijación de sesión. | T01 |
| v5.0.0-7.4.1 | L1 | Impedir el uso de sesiones cerradas o caducadas. | Reutilización de cookie después de logout. | T01 |
| v5.0.0-8.2.1 | L1 | Restringir operaciones por permisos explícitos en APIs y administración. | Pruebas de permisos por rol. | T04, T06 |
| v5.0.0-8.2.2 | L1 | Comprobar propiedad/autorización en pedidos y direcciones específicas. | Tests IDOR/BOLA con clientes diferentes. | T04 |
| v5.0.0-8.3.1 | L1 | Imponer autorización en la capa de servicio confiable, nunca solo en React. | Revisión de middleware, servicios y tests HTTP. | T04, T06 |
| v5.0.0-11.3.2 | L1 | Utilizar cifrados y modos aprobados, como AES-GCM, cuando se requiera. | Inspección de uso de bibliotecas y parámetros. | T10, T12 |
| v5.0.0-12.1.1 | L1 | Permitir versiones TLS recomendadas, priorizando la más reciente. | Pruebas de protocolo y configuración del proxy. | T10 |
| v5.0.0-13.3.1 | L2 | Gestionar secretos fuera del código y de los artefactos de despliegue. | Revisión de repositorio, variables y almacén de secretos. | T10, T11 |

**Continuación tabla 2**

| Código | Nivel | Requisito adaptado al e-commerce | Evidencia prevista | Amenaza |
|---|---|---|---|---|
| v5.0.0-14.1.1 | L2 | Identificar y clasificar datos personales y transaccionales sensibles. | Diccionario de datos y matriz de clasificación. | T04, T10 |
| v5.0.0-14.2.2 | L2 | Evitar que cachés intermedias almacenen información sensible. | Pruebas de caché en cuenta y pedidos. | T04 |
| v5.0.0-15.1.1 | L1 | Definir plazos de actualización y remediación de componentes de terceros. | Política de dependencias y tickets de seguridad. | T06, T11 |
| v5.0.0-15.1.2 | L2 | Mantener inventario/SBOM de bibliotecas y fuentes confiables. | Lista de paquetes e imágenes con versiones. | T06, T11 |
| v5.0.0-16.3.1 | L2 | Registrar eventos de autenticación exitosos y fallidos. | Logs anonimizados y pruebas de login. | T01, T03 |
| v5.0.0-16.3.2 | L2 | Registrar autorizaciones denegadas sin exponer datos. | Pruebas de rechazo y revisión de eventos. | T03, T04 |
| v5.0.0-16.4.2 | L2 | Proteger logs contra acceso y modificación no autorizada. | Revisión de permisos e integridad de registros. | T03, T11 |
| v5.0.0-16.5.1 | L2 | Devolver errores genéricos sin stack traces ni secretos. | Pruebas de excepciones y respuesta HTTP. | T08, T10 |

Nota. Los identificadores y niveles corresponden a OWASP ASVS 5.0.0. Fuente: Elaboracion Propia

## Definición del Scope Técnico

El grupo construirá la aplicación y administrará el proceso de entrega desde el repositorio hasta el ambiente cloud. La arquitectura propuesta contempla un navegador, un componente de perímetro con HTTPS y WAF, una interfaz desarrollada en React, una API REST en Node.js/Express y PostgreSQL en una red privada. Se prevé almacenamiento de objetos, un mecanismo de gestión de secretos, registros de seguridad y un flujo de integración y despliegue continuo. El diseño definitivo se establecerá al seleccionar el proveedor de nube y los servicios disponibles.

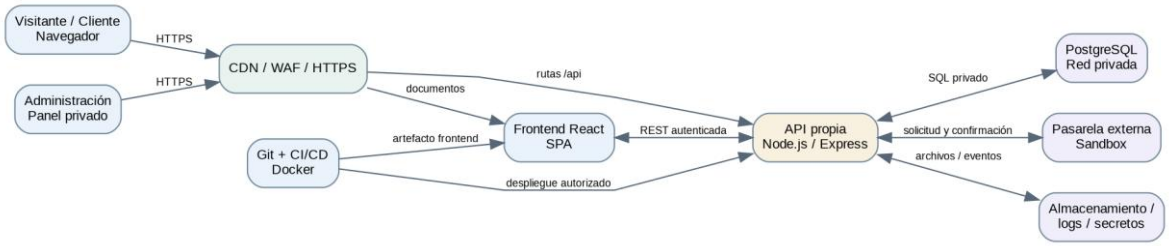
Los datos de precios, cantidades, descuentos e identidad enviados desde el navegador deberán comprobarse nuevamente en la API. Las operaciones administrativas requerirán permisos específicos y el servicio de pagos externo deberá validar las notificaciones recibidas. La separación entre los servicios públicos e internos permitirá establecer reglas de red y acceso acordes con las necesidades de cada componente.

**Tabla 3. Alcance técnico de referencia**

| Ámbito | Componente | Función y límite |
|---|---|---|
| Usuarios | Navegador / SPA React | Visualización de productos, autenticación, carrito y pedidos. |
| Perímetro | HTTPS / CDN / WAF / proxy | Filtra tráfico de internet y enruta al frontend/API. |
| Aplicación propia | Node.js / Express / REST | Reglas de negocio, autorización, estados y pagos. |
| Persistencia | PostgreSQL privada | Usuarios, inventario, compras, pedidos y auditoría. |
| Contenido | Almacén cloud de objetos | Imágenes públicas, archivos permitidos y respaldos privados. |
| Pagos | Proveedor externo sandbox | Token/referencia, respuesta de pago y webhook verificado. |
| Operaciones | Git, CI/CD, Docker, logs, secretos | Compilación, pruebas, despliegue, observabilidad y recuperación. |

Nota. Fuente: Elaboración Propia

**Figura 1. Flujo de datos conceptual y fronteras de confianza**




Nota. Elaboración propia. El diagrama representa la arquitectura de referencia del proyecto. Su configuración y las tecnologías escogidas se revisarán durante el diseño y el despliegue.

El modelo identifica cinco fronteras de confianza. F1 comprende la comunicación entre el navegador y el perímetro público. F2 corresponde al acceso desde el perímetro a la API. F3 separa la API de los datos y servicios internos. F4 abarca la comunicación con el proveedor de pagos y F5 conecta el repositorio y la cadena de entrega con los ambientes de ejecución. Estos límites servirán para definir controles de identidad, autorización, validación de mensajes y protección de credenciales.

## Activos y Riesgos

### Inventario de Activos (ISO 27001)

El inventario reúne activos asociados con las funciones y los servicios previstos para la tienda. Incluye información de clientes, pedidos, código fuente, bases de datos, recursos cloud, registros, personas y continuidad del negocio. Los responsables se identifican por función, ya que las asignaciones individuales dependerán de la organización del equipo. El inventario se actualizará cuando se definan los recursos reales y sus custodios (ISO & IEC, 2022b).

**Tabla 4. Inventario de activos, responsables y acceso**

| ID / activo | Tipo / ubicación | Proceso | Propietario / custodio | Usuarios autorizados |
|---|---|---|---|---|
| A01 · Cuentas y datos personales | Información · Cloud / BD | Registro y atención | Responsable del negocio / DBA / seguridad | Cliente titular; soporte autorizado |
| A02 · Pedidos, precios y transacciones | Información · Cloud / BD | Proceso de compra | Responsable comercial / Backend / DBA | Cliente titular; gestor |
| A03 · Frontend React propio | Software · Repositorio / cloud | Catálogo y tienda | Líder frontend / Desarrollador frontend | Visitantes y clientes |
| A04 · API Node.js y reglas de negocio | Software · Repositorio / cloud | Lógica de compra | Líder backend / Desarrollador backend | Servicios/roles autorizados |
| A05 · Credenciales, sesiones y claves | Información · Cloud / secretos | Autenticación | Responsable seguridad / IAM / operaciones | Titulares; servicios autorizados |
| A06 · Endpoints REST y webhooks | Servicios · Cloud / API | Comunicación y pagos | Líder backend / Backend / DevOps | Clientes y pasarela autorizada |
| A07 · Referencias y estados de cobro | Información · Cloud / BD | Conciliación | Responsable financiero / Backend / finanzas | Finanzas; cliente titular |
| A08 · PostgreSQL gestionada | Servicios · Cloud / red privada | Persistencia | Líder técnico / DBA / proveedor cloud | API; DBA restringido |

**Continuación tabla 4**

| ID / activo | Tipo / ubicación | Proceso | Propietario / custodio | Usuarios autorizados |
|---|---|---|---|---|
| A09 · Imágenes Docker / runtime | Software · Cloud / contenedor | Ejecución y escalado | Líder técnico / DevOps | Operaciones autorizadas |
| A10 · WAF, proxy, DNS y certificados | Servicios · Cloud / perímetro | Protección y acceso | Responsable seguridad / Operador cloud | Tráfico público; DevOps |
| A11 · Imágenes, archivos y backups | Información · Cloud / objetos | Contenido y recuperación | Líder técnico / Operador respaldos | Público en imágenes; privado en copias |
| A12 · Logs de auditoría y seguridad | Información · Cloud / observabilidad | Detección e investigación | Responsable seguridad / Operaciones / seguridad | Analista y auditor autorizado |
| A13 · Código fuente, IaC y pipeline | Software · Repositorio / CI/CD | Cambios y publicación | Líder técnico / DevOps | Desarrolladores autorizados |
| A14 · Equipo con privilegios | Personal · Local / remoto | Administración y desarrollo | Coordinador de grupo / Coordinador seguridad | Administración, DevOps y soporte |
| A15 · Continuidad y confianza del negocio | Empresa · Negocio / cloud | Ventas y reputación | Responsable negocio / Coordinación proyecto | Clientes y titulares del proyecto |

*Nota.* Los activos reflejan las decisiones de diseño. La nomenclatura y los responsables se completarán con identificadores reales, versión y región tras el despliegue. Fuente: Elaboracion Propia

### Clasificación CIA y Criticidad

Se aplica una escala ordinal de 1 a 3 para cada dimensión CIA: baja (B = 1), media (M = 2) y alta (A = 3). La criticidad del activo es la suma de las tres valoraciones (C + I + D); una suma entre 3 y 4 se interpreta como baja, entre 5 y 7 como media y entre 8 y 9 como alta. Esta suma es una convención del proyecto, no una fórmula de ISO/IEC 27001. La valoración expresa una prioridad relativa que deberá revalidarse con el responsable del negocio.

**Tabla 5. Valoración CIA y justificación de criticidad**

| Activo | C | I | D | Criticidad | Justificación |
|---|---|---|---|---|---|
| A01 | A | A | A | 9/9 · Alta | Exposición de datos personales, alteración o indisponibilidad de registros. |
| A02 | A | A | A | 9/9 · Alta | Precios y pedidos alterados perjudican la integridad del cobro. |
| A03 | M | A | A | 8/9 · Alta | Alteración o indisponibilidad del frontend reduce ventas y confianza. |
| A04 | M | A | A | 8/9 · Alta | Fallas de la API propia alteran operaciones y pueden filtrar información. |
| A05 | A | A | A | 9/9 · Alta | Las credenciales permiten suplantación y toma de control. |
| A06 | M | A | A | 8/9 · Alta | APIs y webhooks adulterados modifican pedidos o respuestas. |
| A07 | A | A | M | 8/9 · Alta | Integridad y confidencialidad de la referencia de cobro. |
| A08 | A | A | A | 9/9 · Alta | Persistencia principal de datos personales e inventario. |
| A09 | M | A | A | 8/9 · Alta | Disponibilidad e integridad del runtime afectan el servicio. |
| A10 | M | A | A | 8/9 · Alta | Pérdida de controles perimetrales y acceso al sitio. |
| A11 | A | A | A | 9/9 · Alta | Respaldos contienen datos y permiten restauración. |
| A12 | A | A | M | 8/9 · Alta | La integridad de logs es esencial para investigar incidentes. |
| A13 | A | A | A | 9/9 · Alta | El código propio y el pipeline pueden distribuir defectos o código malicioso. |
| A14 | A | A | M | 8/9 · Alta | Accesos privilegiados y formación afectan controles. |
| A15 | M | A | A | 8/9 · Alta | La alteración del servicio puede afectar reputación y continuidad. |

*Nota.* C = confidencialidad, I = integridad y D = disponibilidad. Escala propuesta y estimaciones propias.

## Modelado de Amenazas (STRIDE)

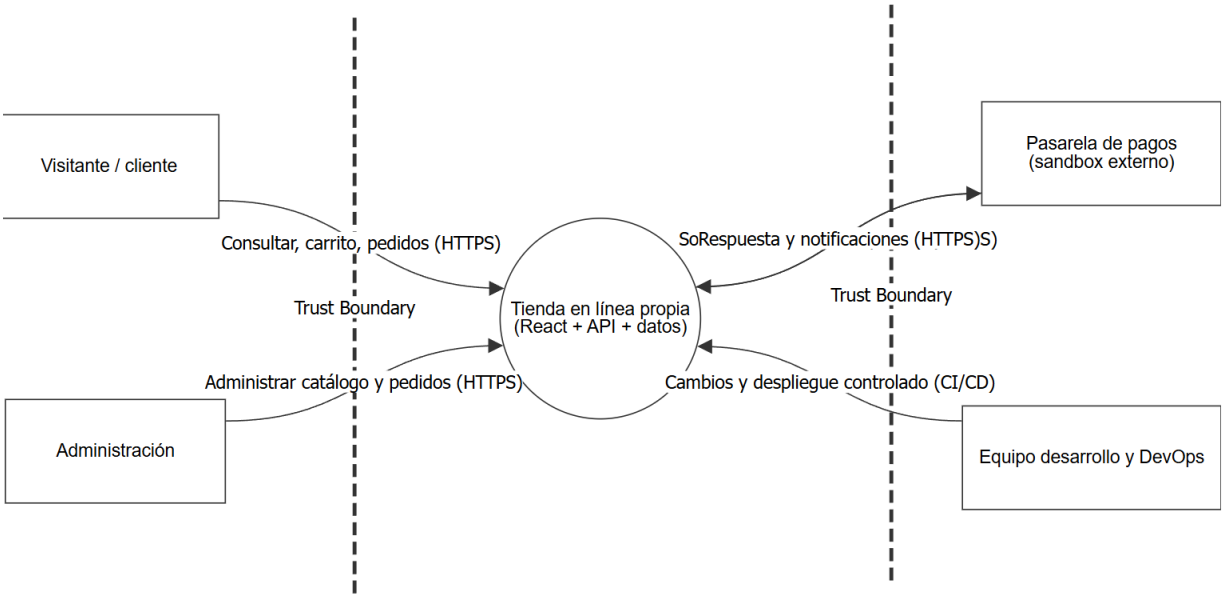
El modelo se construye recorriendo los componentes de la Figura 1 y sus flujos, con especial atención al checkout, la gestión de inventario, las sesiones y el despliegue. STRIDE separa seis tipos de amenaza: S (suplantación), T (manipulación), R (repudio), I (divulgación), D (denegación de servicio) y E (elevación de privilegios). Cada Txx representa un caso posible, no un hallazgo técnico. Microsoft recomienda aplicar esta clasificación sobre diagramas y límites de confianza durante el diseño (Microsoft, 2022).

### *Diagrama de contexto, nivel 0*

El diagrama de contexto presenta una visión general de la tienda en línea y su interacción con los actores externos. Se identifican los clientes que consultan productos y realizan pedidos, el personal administrativo encargado de las operaciones comerciales y el equipo responsable del desarrollo y despliegue de la aplicación. También se incluye la pasarela de pagos externa, que permitirá simular las transacciones durante las pruebas del sistema.

Este primer nivel permite reconocer las principales interacciones con la aplicación y establecer los límites que deberán considerarse durante el análisis de seguridad. Entre ellos se encuentran el acceso de los usuarios desde Internet y la comunicación con el proveedor de pagos. Estas relaciones servirán como referencia para identificar posibles amenazas de suplantación de identidad, manipulación de información y acceso no autorizado.

**Figura 2. Diagrama de contexto de nivel 0 de la tienda en línea**




Fuente: Elaboración propia

***Diagrama de arquitectura y flujo de datos, nivel 1***

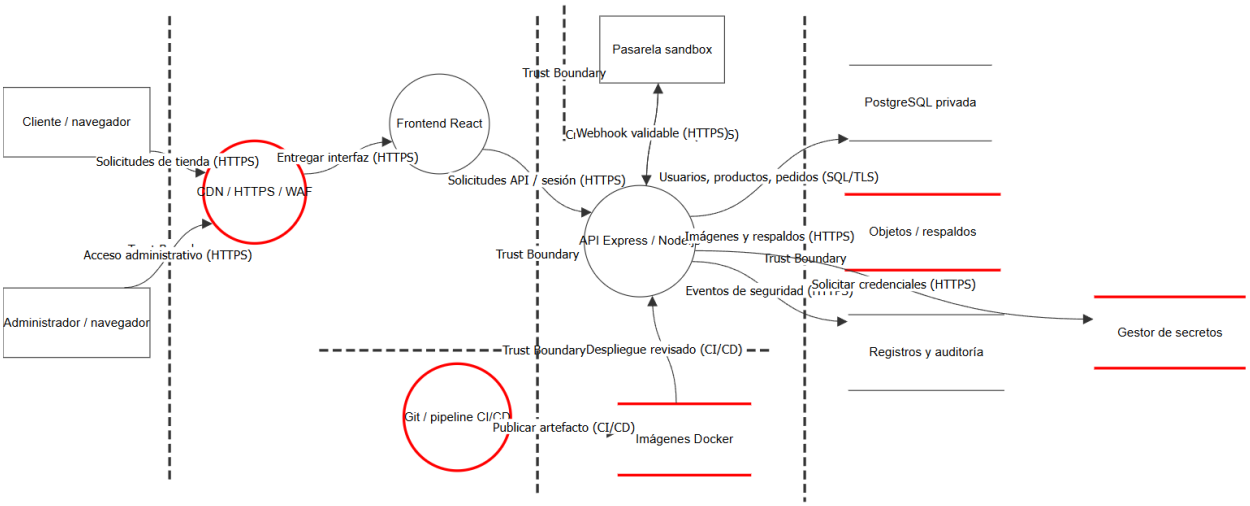
En el segundo diagrama se presenta la distribución de los componentes técnicos que formarán parte de la tienda en línea. La arquitectura propuesta contempla una interfaz desarrollada en React, una API construida con Node.js y Express, y una base de datos PostgreSQL. También se incluyen los servicios relacionados con la protección perimetral, el almacenamiento de archivos, la gestión de secretos y el proceso de integración y despliegue continuo.

El diagrama permite observar el recorrido de la información entre los componentes y las fronteras de confianza identificadas durante el diseño. Estas separaciones resultan necesarias porque las solicitudes provenientes de Internet, las comunicaciones internas y los procesos de despliegue tienen diferentes condiciones de acceso.

En este nivel se representan cinco escenarios de amenaza relacionados con la disponibilidad del servicio, las dependencias de software, la exposición de información sensible y la integridad de los artefactos de despliegue. Los elementos señalados en rojo corresponden a componentes con amenazas pendientes de tratamiento.

Su identificación servirá para definir los controles técnicos y las verificaciones que se realizarán durante las siguientes fases del proyecto.

**Figura 3. Arquitectura y fronteras de confianza**




Fuente: Elaboración propia

### *Diagrama de procesos internos, nivel 2*

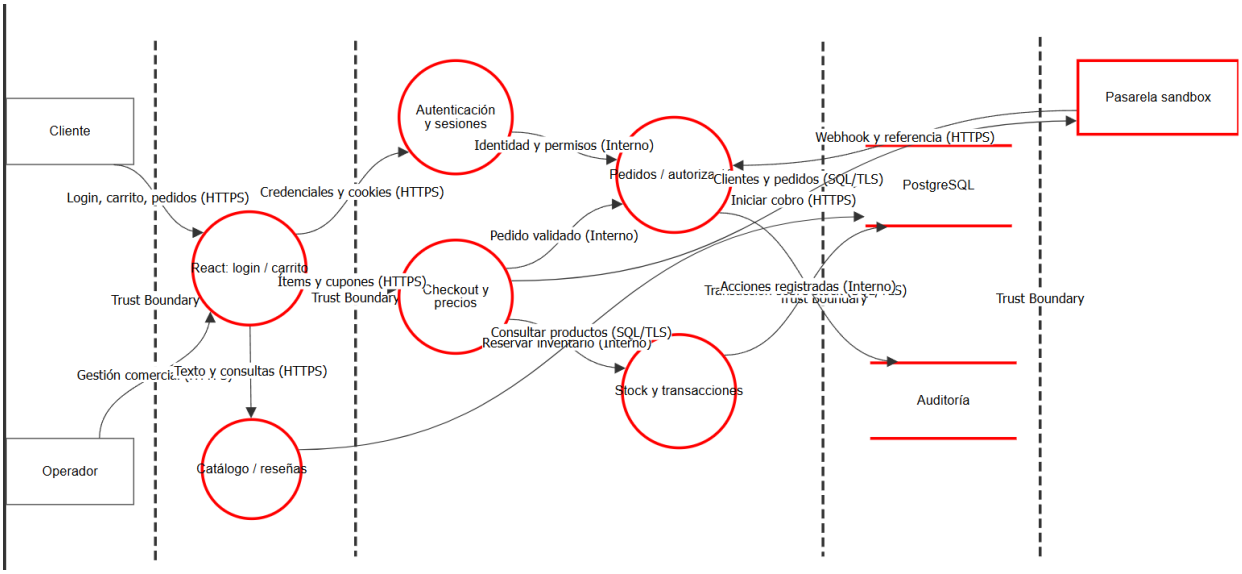
El tercer nivel desarrolla con mayor detalle los procesos internos de la aplicación, principalmente aquellos relacionados con la autenticación de usuarios, la administración del carrito, el registro de pedidos, la actualización de existencias y la comunicación con el servicio de pagos.

El modelo permite identificar cómo interactúan los diferentes procesos con la base de datos y los mecanismos de autorización. También incorpora las operaciones de auditoría que permitirán registrar acciones relevantes dentro del sistema. Esta separación facilita el análisis de situaciones en las que un usuario podría intentar consultar información ajena, modificar valores comerciales o ejecutar operaciones sin los permisos correspondientes.

Entre los escenarios identificados se encuentran los intentos de suplantación de identidad, la manipulación de precios y descuentos, los ataques XSS y SQLi, la falsificación de solicitudes y las condiciones de concurrencia sobre el inventario. También se consideran la verificación de notificaciones de pago y el registro de cambios administrativos.

Los componentes identificados en rojo representan procesos o recursos que requieren medidas de protección. Estas amenazas serán utilizadas como referencia para establecer pruebas de autorización, validación de datos, protección de sesiones e integridad de las transacciones. Su tratamiento deberá comprobarse posteriormente mediante pruebas sobre la aplicación desarrollada.

**Figura 4. Procesos de autenticación y compra**




*Nota*. Fuente: Elaboración propia

**Tabla 6. Identificación de amenazas STRIDE**

| ID | STRIDE | Frontera | Escenario potencial | Activos | Control candidato |
|---|---|---|---|---|---|
| T01 | S | F1/F2 | Intentos de fuerza bruta o credential stuffing contra usuarios y administradores. | A01, A05, A14 | MFA, rate limit y alertas. |
| T02 | T | F1/F2 | Cliente modifica precio, cupón, subtotal o estado de compra enviado por React. | A02, A04 | Cálculo y validación exclusivamente en API. |
| T03 | R | F2/F3 | Un operador modifica pedidos o existencias sin registro de autor y momento. | A02, A12 | Auditoría de acciones sensibles y protección de logs. |
| T04 | I/E | F2/F3 | Un usuario consulta pedidos o direcciones ajenas cambiando identificadores (IDOR). | A01, A02, A06 | Autorización por recurso y función en backend. |
| T05 | D | F1/F2 | Automatización de búsquedas, login o checkout agota recursos del servicio. | A04, A09, A10 | Límites, caché segura, WAF y capacidad. |
| T06 | E/T | F5 | Dependencia npm o imagen de contenedor comprometida llega a producción. | A04, A09, A13 | SCA/SBOM, firmas, actualizaciones y CI/CD controlado. |

**Continuación tabla 6**

| ID | STRIDE | Frontera | Escenario potencial | Activos | Control candidato |
|---|---|---|---|---|---|
| T07 | T/I | F1/F2 | XSS por reseñas, campos de productos o texto mostrado al cliente. | A03, A04 | Escape de salida y renderizado seguro. |
| T08 | T/I | F2/F3 | Inyección SQL mediante parámetros de filtrado o búsqueda de productos. | A01, A04, A08 | Consultas parametrizadas y validaciones. |
| T09 | S/T | F4 | Webhook de pagos falso o repetido marca pedidos como pagados. | A02, A06, A07 | Verificación criptográfica e idempotencia. |
| T10 | I | F3/F5 | Filtración de secretos API, base de datos o backups desde repositorios. | A05, A11, A13 | Gestor de secretos, acceso mínimo y rotación. |
| T11 | T/E | F5 | Pipeline comprometido publica una imagen o versión del backend no autorizada. | A09, A13 | Protección de ramas y aprobaciones de despliegue. |
| T12 | I | F3 | Respaldos o archivos privados expuestos por permisos de almacenamiento. | A01, A11 | Buckets privados, cifrado y retención. |

**Continuación tabla 6**

| ID | STRIDE | Frontera | Escenario potencial | Activos | Control candidato |
|---|---|---|---|---|---|
| T13 | T | F1/F2 | Acciones de cuenta o panel provocadas por solicitudes CSRF. | A03, A05 | Cookies seguras y protección antifalsificación. |
| T14 | T/D | F2/F3 | Dos solicitudes simultáneas agotan el mismo stock o crean pedidos inconsistentes. | A02, A04, A08 | Transacciones y control de concurrencia. |

*Nota.* Los catorce escenarios son hipótesis derivadas del diseño de referencia; una amenaza puede tener más de una categoría STRIDE. Ninguno representa una vulnerabilidad demostrada.

## Clasificación de Riesgos (DREAD)

DREAD evalúa cinco dimensiones: daño potencial (D), reproducibilidad (R), facilidad de explotación (E), usuarios afectados (A) y facilidad de descubrimiento (D). Cada factor recibe una puntuación entre 1 y 10 y el resultado es el promedio aritmético. DREAD se emplea aquí como una rúbrica académica de priorización relativa de cinco factores; los valores y umbrales son convenciones definidas por el grupo, no una escala prescrita por ISO/IEC, OWASP ni Microsoft.

Fórmula aplicada: DREAD = (Daño + Reproducibilidad + Explotabilidad + Usuarios afectados + Descubribilidad) / 5. Interpretación interna propuesta: baja, 1,0–3,9; media, 4,0–6,9; alta, 7,0–8,4; crítica, 8,5–10,0. Estos intervalos son convenciones académicas del equipo y no umbrales oficiales de OWASP o ISO.

**Tabla 7. Puntuación preliminar DREAD por escenario**

| Amenaza | Daño | Reprod. | Exploit. | Afectados | Descubr. | Promedio | Prioridad |
|---|---|---|---|---|---|---|---|
| T01 | 9 | 8 | 9 | 8 | 9 | 8.6 | Crítica |
| T02 | 9 | 7 | 7 | 8 | 7 | 7.6 | Alta |
| T03 | 7 | 8 | 8 | 7 | 8 | 7.6 | Alta |
| T04 | 10 | 7 | 7 | 9 | 7 | 8.0 | Alta |
| T05 | 8 | 8 | 8 | 9 | 9 | 8.4 | Alta |
| T06 | 10 | 8 | 9 | 9 | 9 | 9.0 | Crítica |
| T07 | 8 | 8 | 8 | 8 | 8 | 8.0 | Alta |
| T08 | 10 | 7 | 7 | 9 | 7 | 8.0 | Alta |
| T09 | 9 | 7 | 6 | 8 | 6 | 7.2 | Alta |
| T10 | 10 | 7 | 7 | 9 | 7 | 8.0 | Alta |
| T11 | 10 | 6 | 6 | 10 | 6 | 7.6 | Alta |
| T12 | 9 | 8 | 7 | 8 | 7 | 7.8 | Alta |
| T13 | 7 | 7 | 7 | 7 | 8 | 7.2 | Alta |
| T14 | 8 | 7 | 7 | 7 | 7 | 7.2 | Alta |

*Nota.* Puntuaciones elaboradas por el equipo. Todos los factores utilizan la misma escala ordinal de 1 a 10

### Matriz de Riesgos Inicial

La segunda valoración es independiente de DREAD y busca estimar la exposición inicial del negocio. Se asigna probabilidad (P) e impacto (I) de 1 a 5. La valoración es P × I y se interpreta como baja (1–4), media (5–9), alta (10–16) y crítica (17–25). Los niveles son propios del proyecto y se revisarán luego de conocer controles existentes, vulnerabilidades efectivas y exposición real. ISO/IEC 27005 orienta la gestión del riesgo, pero no prescribe estos umbrales particulares (ISO & IEC, 2022a).

**Tabla 8. Criterios de probabilidad e impacto**

| Valor | Probabilidad (P) | Impacto (I) |
|---|---|---|
| 1 | Muy rara | Impacto insignificante |
| 2 | Poco probable | Impacto menor |
| 3 | Posible | Impacto moderado |
| 4 | Probable | Impacto mayor |
| 5 | Muy probable | Impacto crítico |

*Nota*. Fuente: Elaboración propia

**Tabla 9. Registro de riesgos inherentes estimados**

| ID | P | I | P × I | Nivel |
|---|---|---|---|---|
| T01 | 5 | 4 | 20 | Crítica |
| T02 | 3 | 5 | 15 | Alta |
| T03 | 4 | 3 | 12 | Alta |
| T04 | 4 | 5 | 20 | Crítica |
| T05 | 4 | 4 | 16 | Alta |
| T06 | 4 | 5 | 20 | Crítica |
| T07 | 4 | 4 | 16 | Alta |
| T08 | 3 | 5 | 15 | Alta |
| T09 | 3 | 5 | 15 | Alta |
| T10 | 3 | 5 | 15 | Alta |
| T11 | 3 | 5 | 15 | Alta |
| T12 | 3 | 5 | 15 | Alta |
| T13 | 4 | 3 | 12 | Alta |
| T14 | 4 | 4 | 16 | Alta |

*Nota.* Riesgo inherente = estimación antes de verificar medidas específicas. No debe confundirse con riesgo residual posterior a la implementación. Fuente: Elaboracion Propia

### Matriz de calor (probabilidad × impacto)

### Tabla 10 Matriz de calor inicial

| P / I | I=1 | I=2 | I=3 | I=4 | I=5 |
|---|---|---|---|---|---|
| 5 | 5 | 10 | 15 | 20<br>T01 | 25 |
| 4 | 4 | 8 | 12<br>T03, T13 | 16<br>T05, T07, T14 | 20<br>T04, T06 |
| 3 | 3 | 6 | 9 | 12 | 15<br>T02, T08, T09, T10, T11, T12 |
| 2 | 2 | 4 | 6 | 8 | 10 |
| 1 | 1 | 2 | 3 | 4 | 5 |

*Nota.* Colores: bajo = verde, medio = amarillo, alto = naranja y crítico = rojo. Fuente: Elaboracion Propia

### Análisis obligatorio de siete capas de defensa

### Tabla 11. Riesgos y controles iniciales en siete capas

| Capa | Amenazas / exposición | Control recomendado | Trazabilidad |
|---|---|---|---|
| 1. Datos | Divulgación de clientes, pedidos, credenciales y respaldos. | Clasificación, cifrado, retención, acceso y gestión de claves. | T04, T10, T12 |
| 2. Aplicación | Código: XSS/SQLi; lógica: precios/stock; implementación: bibliotecas; perímetro: API/webhooks. | Validación backend, escape, SQL parametrizado, transacciones, RBAC, SCA. | T02, T04, T06–T09, T13–T14 |
| 3. Host | Imagen base desactualizada o runtime con permisos excesivos. | Imagen mínima, no root, parches, escaneo y secretos externos. | T06, T11 |
| 4. Red interna | Conexión indebida a PostgreSQL, secretos u objetos privados. | Red privada, firewall, identidad entre servicios, acceso mínimo. | T04, T10, T12 |

**Continuación tabla 11**

| Capa | Amenazas / exposición | Control recomendado | Trazabilidad |
|---|---|---|---|
| 5. Perímetro cloud/red | Bots, fuerza bruta, DoS o tráfico de origen no confiable. | TLS, WAF, rate limit y controles de red. | T01, T05, T07 |
| 6. Seguridad física | Fallos del centro de datos o soporte físico del proveedor. | SLA, continuidad, redundancia, evaluación de certificaciones. | T05, T12 |
| 7. Personas y políticas | Errores de configuración, acceso privilegiado o cambio inseguro. | MFA, revisiones de código, cambios aprobados, incidentes, formación. | T01, T03, T06, T11 |

*Nota.* Se conservan las subdivisiones exigidas para la capa de aplicación: código, lógica de aplicación, implementación y perímetro de aplicación. Fuente: Elaboración Propia

## Tratamiento preliminar y responsables

### Tabla 12. Plan inicial de tratamiento por amenaza

| Amenaza | Decisión | Acción inicial propuesta | Responsable por rol |
|---|---|---|---|
| T01 | Mitigar | MFA administrativa, rate limit y detección de accesos. | Seguridad / backend |
| T02 | Mitigar | Recalcular importes y validar promociones en API. | Backend |
| T03 | Mitigar | Auditoría inalterable de pedidos y cambios de stock. | Backend / seguridad |
| T04 | Mitigar | Permisos por objeto y rol en todos los endpoints. | Backend / QA |

**Continuación tabla 12**

| Amenaza | Decisión | Acción inicial propuesta | Responsable por rol |
|---|---|---|---|
| T05 | Mitigar | Cuotas, caché segura, límites y WAF. | Cloud / DevOps |
| T06 | Mitigar | SBOM, SCA, fijación de versiones e imágenes confiables. | Desarrollo / DevOps |
| T07 | Mitigar | Escape contextual, renderizado seguro y tests XSS. | Frontend / backend |
| T08 | Mitigar | Consultas parametrizadas y pruebas SQLi. | Backend / DBA |
| T09 | Mitigar | Firma, consulta del estado al proveedor e idempotencia. | Backend / pagos |
| T10 | Mitigar | Secret manager, rotación, acceso mínimo y repos privados. | DevOps / seguridad |
| T11 | Mitigar | Protección de ramas, revisión y validación de artefactos. | DevOps |
| T12 | Mitigar | Almacenamiento privado, cifrado, backups probados. | Cloud / operaciones |
| T13 | Mitigar | Antifalsificación, validación de Origin/SameSite. | Frontend / backend |
| T14 | Mitigar | Transacciones y bloqueo/concurrencia por stock. | Backend / DBA |

*Nota.* Plan inicial de tratamiento por amenaza. Fuente: Elaboración Propia

## Evaluación de Seguridad

**Pentesting Caja Negra**

**Pentesting Caja Gris / Blanca**

**Evaluación OWASP Web Top 10**

**Evaluación de componentes y librerías**

**SAST del frontend y backend**

**SCA de dependencias de la aplicación**

**Evaluación de Contenedores y Kubernetes**

## Mitigación y Ciberseguridad

**Rediseño Arquitectónico Cloud Seguro**

**Controles de Seguridad Propuestos**

**Hardening de la aplicación web**

**Hardening del frontend y backend**

**Hardening de Contenedores**

**Hardening de Infraestructura Cloud**

**Implementación de Controles DevSecOps**

## Operaciones y Monitoreo

**WAF**

**RASP / Protección en Tiempo de Ejecución**

**SIEM / Correlación de Eventos**

**Alertas y Dashboards**

**Gestión Continua de Vulnerabilidades**

## Tratamiento del Riesgo

# Conclusiones

## Recomendaciones Técnicas

## Roadmap de Seguridad Continua

## Lecciones Aprendidas

## Anexos

Los diagramas, el informe de amenazas y el archivo JSON del modelo elaborado en OWASP Threat Dragon pueden consultarse en el siguiente enlace. Para visualizar los documentos se debe de ingresar con el correo institucional

https://drive.google.com/drive/folders/1bgSF1kBpVkYUcx9u8OoYcGvA_rlGousD?usp=sharing

## Referencias


International Organization for Standardization & International Electrotechnical Commission. (2022a). *Information security, cybersecurity and privacy protection—Guidance on managing information security risks (ISO/IEC Standard No. 27005:2022).* https://www.iso.org/standard/80585.html

International Organization for Standardization & International Electrotechnical Commission. (2022b). *Information security, cybersecurity and privacy protection—Information security management systems—Requirements (ISO/IEC Standard No. 27001:2022).* https://www.iso.org/standard/27001

Microsoft. (2022, 25 de agosto). *Threats: Microsoft Threat Modeling Tool. Microsoft Learn.* https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats

OWASP Foundation. (2025a). *OWASP Application Security Verification Standard (ASVS), version 5.0.0.* https://github.com/OWASP/ASVS/tree/v5.0.0/5.0

OWASP Foundation. (s. f.). OWASP Threat Dragon. https://owasp.org/projects/threat-dragon/

PCI Security Standards Council. (s. f.). *Does PCI DSS apply to merchants who outsource all payment processing operations and never store, process or transmit cardholder data?* https://www.pcisecuritystandards.org/faqs/does-pci-dss-apply-to-merchants-who-outsource-all-payment-processing-operations-and-never-store-process-or-transmit-cardholder-data/

Souppaya, M., Scarfone, K., & Dodson, D. (2022). *Secure software development framework (SSDF) version 1.1: Recommendations for mitigating the risk of software vulnerabilities (NIST SP 800-218). National Institute of Standards and Technology. https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-218.pdf*